

One-Person Company Website Builder — Build Plan

2026-09-17 · @Someone

Summary

We extend the existing app so a solopreneur answers Genie's questions, confirms details in the Setup Wizard, picks a theme, and gets a live website plus a dashboard to run it. Everything is added alongside current code; nothing existing is moved or renamed.

What gets built from the wizard data (schema 2.0):

- **Public website:** one Next.js template with 4 themes (Professional, Warm, Bold, Local). Pages: Home, Offers, Offer detail, About, Work, Insights, FAQ, Contact, Legal.
- **Founder website admin** at `/dashboard/site` : overview, enquiries inbox with AI Sales Desk, page copy, positioning, offers, proof, knowledge base, theme, agents, payments, settings.
- **Backend services:** save the site, generate copy with an LLM plus honesty checks, sync tiers to `Offer` rows, capture enquiries, run the sales agent with owner approval, reuse existing Razorpay/Stripe checkout.

flowchart LR

```

A[Genie questions] --> B[Setup Wizard]
B --> C[Pick theme<br/>live preview]
C --> D[Build: save + copy]
D --> E[Public site<br/>/username]
E --> F[Enquiries]
F --> G[AI Sales Desk<br/>owner approves]
D --> H[Dashboard site admin]

```

Design and layout are code; the LLM only writes copy. Prices, numbers, testimonials and credentials come only from the user.

Code review findings

The most urgent issue: `"/` in `PUBLIC_PATHS` makes every API route public, because matching uses `startswith`. Fix it first, carefully, since some routes may silently depend on it.

Severity	File	Finding	Fix (phase)
Critical	<code>core/middleware.py</code>	<code>"/</code> in <code>PUBLIC_PATHS</code> matches all paths, so the JWT middleware never runs	Exact match for <code>/</code> ; list every truly public route explicitly (Phase 0)
High	<code>core/middleware.py</code>	Reads token only from <code>Authorization</code> header; ignores the <code>token</code> cookie used by <code>frontend/middleware.js</code>	Accept header or cookie, as <code>site_build_routes.py</code> already does (Phase 0)
High	<code>genie_routes.py</code>	Reuses <code>_call_groq_prefill_async</code> from <code>chat_routes.py</code> , which served the old flat format; schema 2.0 output is unverified	Review <code>chat_routes.py</code> ; add schema 2.0 prompt + validation (Phase 1)
High	<code>genie_routes.py</code>	No auth or rate limit on a paid LLM call once middleware is fixed	Add to public paths with per-IP rate limit, or require login (Phase 0-1)
High	<code>site_build_routes.py</code>	Guests get <code>success: true</code> and a preview URL, but nothing is saved or built	Require login; return <code>saved: false</code> as an error (Phase 1)
High	<code>site_build_routes.py</code>	No uniqueness or reserved-name check on <code>subdomain</code> ; URL <code>/ {subdomain}</code> may differ from <code>[username]</code>	New <code>founder_sites</code> table with unique <code>slug</code> ; reserved list (Phase 1)
Medium	<code>site_build_routes.py</code>	Returns success even when <code>db.commit()</code> fails	Return 500 on commit failure (Phase 1)
Medium	<code>site_build_routes.py</code>	Pydantic v1 class <code>Config</code> breaks AGENTS.md style	<code>model_config = ConfigDict(extra="allow")</code> (Phase 1)
Medium	<code>site_build_routes.py</code>	No server-side required-field or honesty validation	Validate positioning + Tier 1; reuse honesty rules (Phase 3)
Medium	<code>user_site_settings.py</code>	No unique constraint on <code>(user_id, key)</code> ; concurrent upserts can duplicate rows	Dedupe, then add unique constraint (Phase 1)

Severity	File	Finding	Fix (phase)
Medium	user_site_settings.py	v1 keys (hero , pricing) and v2 keys share the table	Loaders filter schema_version = '2.0' (Phase 1)
Medium	offer.py	One price + currency ;no tier, USD price, deliverables or highlight	Add nullable tier , price_usd , deliverables (JSONB), is_highlighted , sort_order (Phase 1)
Medium	offer.py	slug not unique per creator; can collide with site page names	Unique (creator_id, slug) + reserved slugs (Phase 1)
Low	genie_routes.py	Unused imports; __import__("json") inline	Clean up (Phase 1)
Low	page.js (wizard)	Matches the delivered wizard; SITE_DOMAIN_SUFFIX is a placeholder; ignores genie_needs_confirmation	Set domain; add "Check" badges (Phase 1)
Low	AI Website Builder page	Calls /api/chat/prefill , not a schema 2.0 endpoint	Point to new /api/genie/intake (Phase 1)

Files not yet reviewed, needed before their phase: chat_routes.py , main.py , settings_routes.py , content_routes.py , payment_routes.py , lead_routes.py , frontend/middleware.js , context/AuthContext.js , next.config.js , app/[username]/[offer-slug]/page.js , alembic/env.py .

Folder structure

New work lives under existing frontend/app/[username] , frontend/app/dashboard and backend/app . Labels: NEW = new file or folder, EXTEND = additive edit, REPLACE = swap file content, untouched = no change.

```
one-person-company/
├── frontend/
│   ├── app/
│   │   ├── [username]/
│   │   │   ├── (site)/
│   │   │   │   ├── NEW route group: themed
│   │   │   │   ├── NEW load site + theme
│   │   │   │   ├── NEW Home → /priya
│   │   │   │   ├── NEW
│   │   │   └── offers/page.js
│   │   └── public site
│   │       ├── layout.js
│   │       ├── page.js
│   │       └── offers/page.js
```

					└─ about/page.js	NEW
					└─ work/page.js	NEW
					└─ insights/page.js	NEW
					└─ faq/page.js	NEW
					└─ contact/page.js	NEW
					└─ legal/[doc]/page.js	NEW
					└─ [offer-slug]/	EXTEND theme-aware (Phase 3)
					└─ community/	untouched
					└─ dashboard/	
					└─ page.js	EXTEND "My website" card
(Phase 5)						
					└─ community/	untouched
					└─ site/	NEW founder website admin
					└─ layout.js page.js	
					└─ enquiries/	inbox, [id], pipeline, sales-
desk						
					└─ pages/ positioning/ offers/ proof/ knowledge/	
					└─ theme/ agents/ payments/ settings/	
					└─ templates/	NEW theme gallery
					└─ page.js	
					└─ [theme]/page.js	
					└─ setup-wizard/page.js	REPLACE new wizard
					└─ setup-wizard-legacy/page.js	NEW old wizard kept until
Phase 3						
					└─ platform/ai-website-builder/page.js	REPLACE new Genie intake
					└─ site-template/	NEW shared, not routes
					└─ schema.js	schema 2.0 defaults +
validation						
					└─ themes/	professional.js warm.js
bold.js local.js						
					└─ sections/	Hero ForWho OfferLadder Proof
Process FaqList Invitation						
					└─ ui/	Button Card Field Table Badge
					└─ lib/	getPublicSite.js
formatPrice.js reserved.js						
					└─ samples/	ca.json coach.json
designer.json bakery.json						
					└─ middleware.js	EXTEND subdomain rewrite
(Phase 7)						
					└─ next.config.js	untouched
					└─ backend/app/	
					└─ api/routes/	

— genie_routes.py	EXTEND + POST
— site_build_routes.py	EXTEND auth, validation,
founder_sites	
— public_site_routes.py	NEW GET /api/public-
site/{slug}	
— site_admin_routes.py	NEW /api/my-site/*
— enquiry_routes.py	NEW /api/enquiries/*
— sales_desk_routes.py	NEW /api/sales-desk/*
— content_routes.py	EXTEND reserved + per-
creator slugs	
— models/	
— founder_site.py	NEW slug, theme, status,
custom_domain	
— site_content.py	NEW copy per page + version
— enquiry.py	NEW Enquiry, EnquiryMessage
— sales_desk.py	NEW SalesDeskSettings,
AgentRun	
— offer.py	EXTEND nullable tier fields
— user_site_settings.py	EXTEND unique (user_id, key)
— services/	
— site_copy_service.py	NEW Claude copy generation
— honesty_validator.py	NEW
— offer_sync_service.py	NEW tiers → Offer rows
— reserved_names.py	NEW
— sales_desk_service.py	NEW
— core/middleware.py	EXTEND public-path fix,
cookie token	
— main.py	EXTEND register routers
— backend/alembic/versions/	NEW migrations 10-14
(additive)	
— backend/tests/test_api/	NEW tests per phase
— nginx/nginx.conf	EXTEND wildcard subdomain
(Phase 7)	

The founder admin lives at `/dashboard/site` because `/admin` is the platform admin and `/dashboard` is already protected by `frontend/middleware.js`. Founder enquiries get a new table so the platform `leads` funnel and `/admin/leads` keep working.

Safety rules

Every change follows these rules so existing features keep working.

1. **Add, don't modify.** New files, new API prefixes, new tables. Edits to existing files are additive only.
2. **Additive migrations.** New columns are nullable. No renames or drops. Import each new model in `alembic/env.py` before `--autogenerate`, and read the generated script before applying.
3. **One database base.** Import `Base`, `SessionLocal`, `get_db` only from `app.core.database`. Never from `app/db/session.py`, `app/db/base.py` or `app/db/init_db.py`.
4. **Exact public paths.** Matching is `startswith`, so add precise paths like `/api/public-site/` and `/api/enquiries/submit`, never broad prefixes.
5. **Project code style.** Frontend: `.js` only, `'use client'` where needed, `useSiteConfig()` on public pages, Tailwind `primary-*` tokens. Backend: Pydantic v2, relative imports in routes, auth errors from `app/core/auth.py`.
6. **Feature flag.** New routes check a `sites_enabled` setting and return 404 until the phase is signed off.
7. **Branch per phase.** `feature/phase-N-name`; merge only after `pytest`, `npm run lint` and `npm run build` pass.
8. **Regression checklist before every merge:** login (email + OAuth), `/admin` pages, `/dashboard`, `/[username]/[offer-slug]`, community pages, Razorpay and Stripe test payment, `/api/chat`, content studio agents, newsletter signup, contact form.
9. **Environment.** Set `SECRET_KEY` in `.env`, or every restart logs all users out.
10. **Back up the database** before each migration: `pg_dump ai_services_platform > backup_phaseN.sql`.

Phase plan

Eight phases, each shippable on its own. Phases 0 and 1 fix risks and connect existing pieces before any new pages exist.

Phase 0: Security fix and baseline

Goal: close the open-API hole without breaking current features.

- ☐ Back up the database
- ☐ List every route in `main.py` and mark which must be public (settings, leads POST, subscribers POST, resources, pages, genie, offers public, payments webhook)

- ☐ Change `/` to an exact match in `_is_public_path`
- ☐ Add each needed public route explicitly to `PUBLIC_PATHS`
- ☐ Accept the `token` cookie as well as the `Authorization` header
- ☐ Add a simple per-IP rate limit on `/api/genie/*` and `/api/chat`
- ☐ Write `tests/test_api/test_public_paths.py`: public routes return 200 without a token; protected routes return 401
- ☐ Run the full regression checklist

Done when: tests pass, regression checklist passes, and an unauthenticated call to a protected route returns 401. Files needed: `main.py`, `chat_routes.py`, `settings_routes.py`, `lead_routes.py`, `frontend/middleware.js`, `context/AuthContext.js`.

Phase 1: Foundation

Goal: data model and APIs that the template will read.

- ☐ Migration 10: `founder_sites` table (`user_id` unique, `slug` unique, `theme`, `status`, `custom_domain`, `published_at`) plus a slug history table so old slugs redirect with a 301
- ☐ Migration 11: `offers` nullable columns `tier`, `price_usd`, `deliverables`, `is_highlighted`, `sort_order`, and site link
- ☐ Migration 12: dedupe then unique (`user_id`, `key`) on `user_site_settings`
- ☐ `services/reserved_names.py`: reserved usernames and offer slugs; a site slug may not match another user's username, an old slug or a top-level route; used in registration, `content_routes.py`, site build
- ☐ `site_build_routes.py`: require login, Pydantic v2 config, slug uniqueness, error on commit failure, create or update `founder_sites`
- ☐ `offer_sync_service.py`: wizard tiers → `Offer` rows (update by tier, never delete paid offers)
- ☐ `genie_routes.py`: add `POST /api/genie/intake` returning `{ prefill, needsConfirmation, followUps }` in schema 2.0; validate shape
- ☐ Frontend: move wizard to `setup-wizard/page.js`; keep old as `setup-wizard-legacy`
- ☐ Frontend: replace AI Website Builder page; point to `/api/genie/intake`
- ☐ Wizard: read `genie_needs_confirmation` and show Check badges; set real `SITE_DOMAIN_SUFFIX`

- ☐ Tests: build saves settings, creates site, syncs offers, rejects reserved slug

Done when: a logged-in user goes Genie → wizard → build, and `founder_sites`, `user_site_settings` (2.0) and `offers` rows exist. Files needed: `chat_routes.py`, `content_routes.py`, `auth_routes.py`, `alembic/env.py`, `models/user.py`.

Phase 2: Public template with sample data

Goal: the site renders correctly without AI or real data.

- ☐ `site-template/schema.js` and 4 sample JSON files
- ☐ `ui/` components and `sections/`
- ☐ Theme tokens for Professional, Warm, Bold, Local
- ☐ `[username]/(site)` pages reading a sample when `?sample=ca`
- ☐ Empty-state rules: proof sections hidden when no data
- ☐ Mobile, accessibility and Lighthouse checks
- ☐ Confirm existing `[offer-slug]` and `community` pages are unchanged

Done when: all pages render for all 4 samples on mobile and desktop.

Phase 3: Real data and copy generation

Goal: a user's own site goes live from their wizard data.

- ☐ Migration 13: `site_content` (site, page key, content JSONB, version, status)
- ☐ `public_site_routes.py`: `GET /api/public-site/{slug}` returns published data only, no private fields (GSTIN, spend caps, agent settings)
- ☐ `site_copy_service.py`: Claude writes copy from schema 2.0; runs in background task
- ☐ `honesty_validator.py`: reject prices, numbers, names or quotes not in the input
- ☐ `(site)` pages read real data; `[offer-slug]` becomes theme-aware
- ☐ Enquiry form posts to existing flow until Phase 6
- ☐ Remove `setup-wizard-legacy`

Done when: build → copy generated → validated → `/username` shows the live site (at its site slug). Files needed: `[username]/[offer-slug]/page.js`, `payment_routes.py`.

Phase 4: Theme gallery and preview

- ☐ `/templates` gallery with live sample demos
- ☐ Preview a user's own data in each theme

- ☐ Replace wizard Step 8 style choice with the theme picker
- ☐ Theme saved on `founder_sites.theme`; switching keeps content

Done when: a user switches theme and the live site updates with no content loss.

Phase 5: Dashboard site admin

- ☐ `/dashboard/site` layout and overview
- ☐ Edit pages copy with preview and publish (versioned); change site slug with availability check and automatic redirect from the old URL
- ☐ Edit positioning, offers (synced to `offer`), proof, knowledge base
- ☐ Theme, brand, agents and payment settings
- ☐ `site_admin_routes.py` under `/api/my-site/*`, owner-only
- ☐ "My website" card on `/dashboard`

Done when: every wizard field is editable after launch and changes appear on the live site.

Phase 6: Enquiries and AI Sales Desk

- ☐ Migration 14: `enquiries`, `enquiry_messages`, `sales_desk_settings`, `agent_runs`
- ☐ Public `POST /api/enquiries/submit` with spam protection
- ☐ Inbox, lead detail, pipeline board, follow-ups due
- ☐ Sales agent: qualify, draft reply from real offers only, suggest next step, schedule follow-ups
- ☐ Approval mode by default; limited auto-send for safe messages; pause switch; daily limit
- ☐ Activity log with reasons; email alert on new enquiry

Done when: an enquiry arrives, the agent drafts a reply, the owner approves and it sends.

Phase 7: Subdomains and custom domains

- ☐ `frontend/middleware.js`: `slug.yourplatform.com` → `/[username]` without breaking auth checks
- ☐ `nginx.conf` wildcard server name and TLS
- ☐ Custom domain verification (DNS TXT) and SSL
- ☐ SEO: sitemap, robots, canonical URLs

Done when: a site loads at its subdomain and a verified custom domain.

Progress tracker

Update the Status column as each phase moves; a phase is Done only when its "Done when" test passes.

Phase	Outcome	Depends on	Status
0. Security fix	API auth works; nothing else breaks	None	Not started
1. Foundation	Genie → wizard → build saves site and offers	0	Not started
2. Template (samples)	All pages render for 4 samples	1	Not started
3. Real data + copy	User's live site at /site-slug	2	Not started
4. Theme gallery	Theme switch with preview	3	Not started
5. Site admin	All content editable after launch	3	Not started
6. Sales Desk	Enquiry → draft → approve → send	5	Not started
7. Domains	Subdomain + custom domain live	3	Not started

Open decisions

- ☐ Platform domain for subdomains (replaces `yourplatform.com`)
- ☐ Copy generation model: Claude for quality, or Groq for lower cost
- ☐ Should guests use Genie before signing up, or require login first
- ☐ Public URL: username only, or a separate site slug a user can change (decided: separate slug, changeable later)